2 CICLO FORMATIVO GRADO SUPERIOR

Administración de Sistemas Informáticos y Redes - ASIR
Administración de Sistemas Gestores de Bases de Datos - ASGBD



Práctica 3 - Creación de usuarios, vistas y permisos

Daniel González Castro

Índice.

Tarea 2. Seguridad mediante Vistas y Privilegios Granulares..... 2

1. Privilegio granular..... 2
2. Prueba de denegación.....3

Tarea 4. Consistencia y control con WITH CHECK OPTION..... 4

1. Demostración técnica..... 4

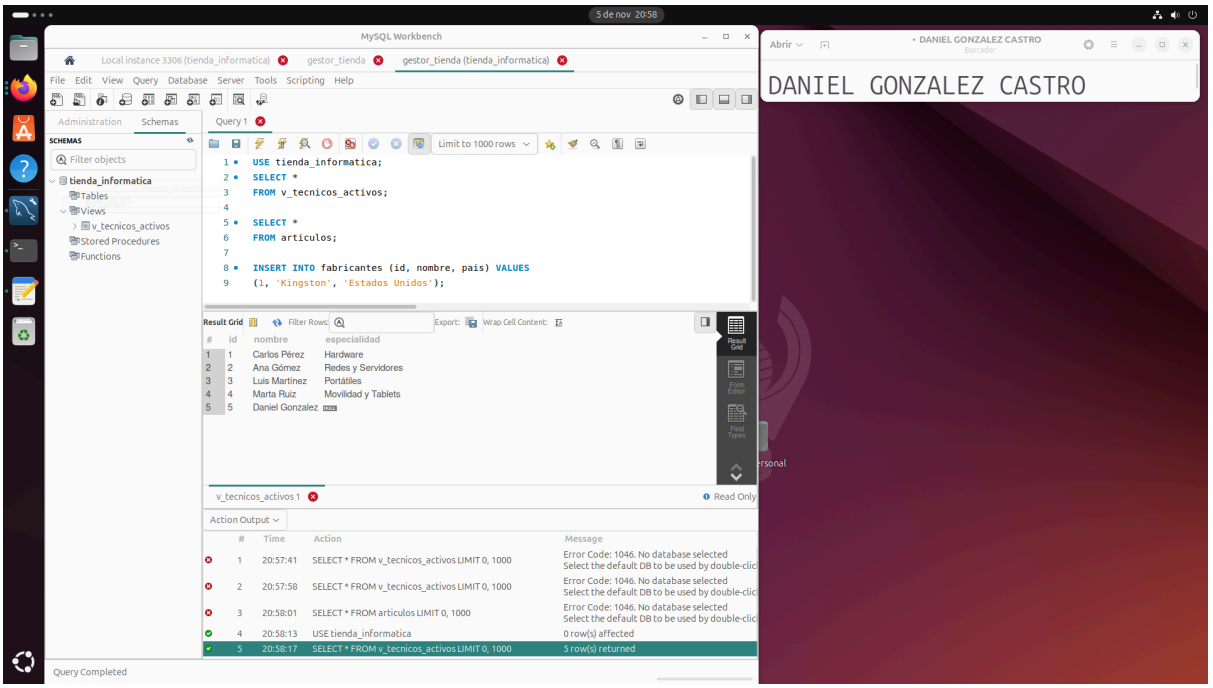
Tarea 5: Auditoría, Resolución de Incidencias y Reflexión Crítica....5

1. Auditoría de privilegios efectivos..... 5
2. Reflexión sobre el Principio de Mínimo Privilegio:.....6
3. Análisis de comportamiento del CHECK OPTION:.....6

Tarea 2. Seguridad mediante Vistas y Privilegios Granulares

1. Privilegio granular.

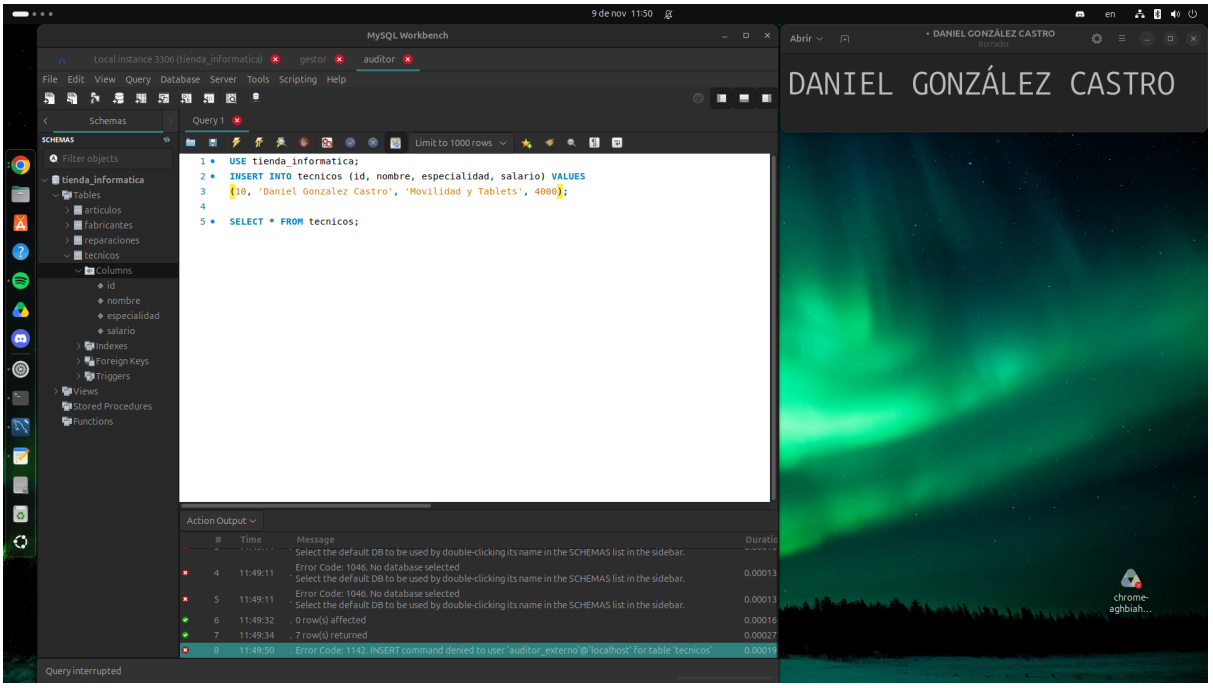
- **Concede al usuario gestor_tienda permisos exclusivos de consulta sobre dicha vista v_tecnicos_activos.**

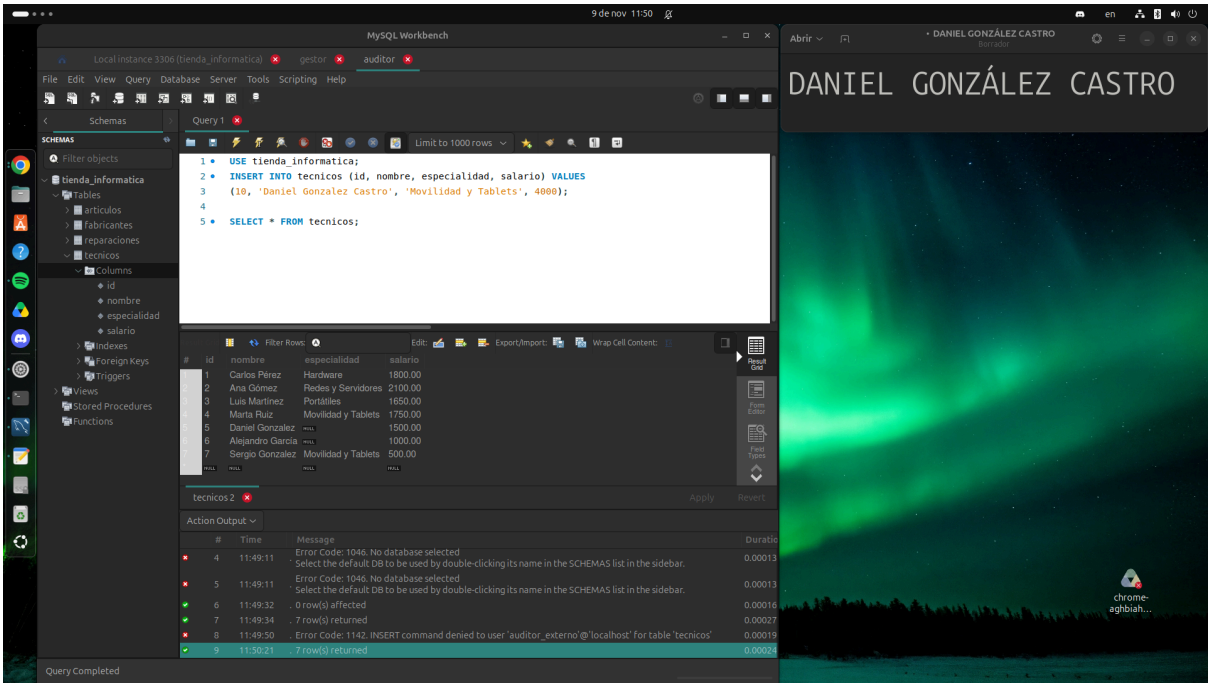


- **Asigna rol_consultor al usuario auditor_externo y configúralo explícitamente como rol por defecto para su sesión de trabajo.**

Hemos creado al usuario auditor_externo pero no le hemos asignado permisos a ese usuario si no que hemos creado un rol_consultor y a ese rol le hemos puesto permisos de SELECT a todas las tablas de la base de datos (tienda_informatica). Para que cada vez que iniciemos sesión con ese usuario tengamos los permisos de ese rol en concreto lo que hay que hacer es ponerle el rol por defecto así cada vez que entre a su sesión de trabajo entre con ese rol y no otro.

Debajo vendrán las capturas de pantalla demostrando que solo tiene permisos de SELECT y no de INSERT por ejemplo. Al intentar insertar datos nos salta un error de permisos igual que en el caso anterior.





2. Prueba de denegación.

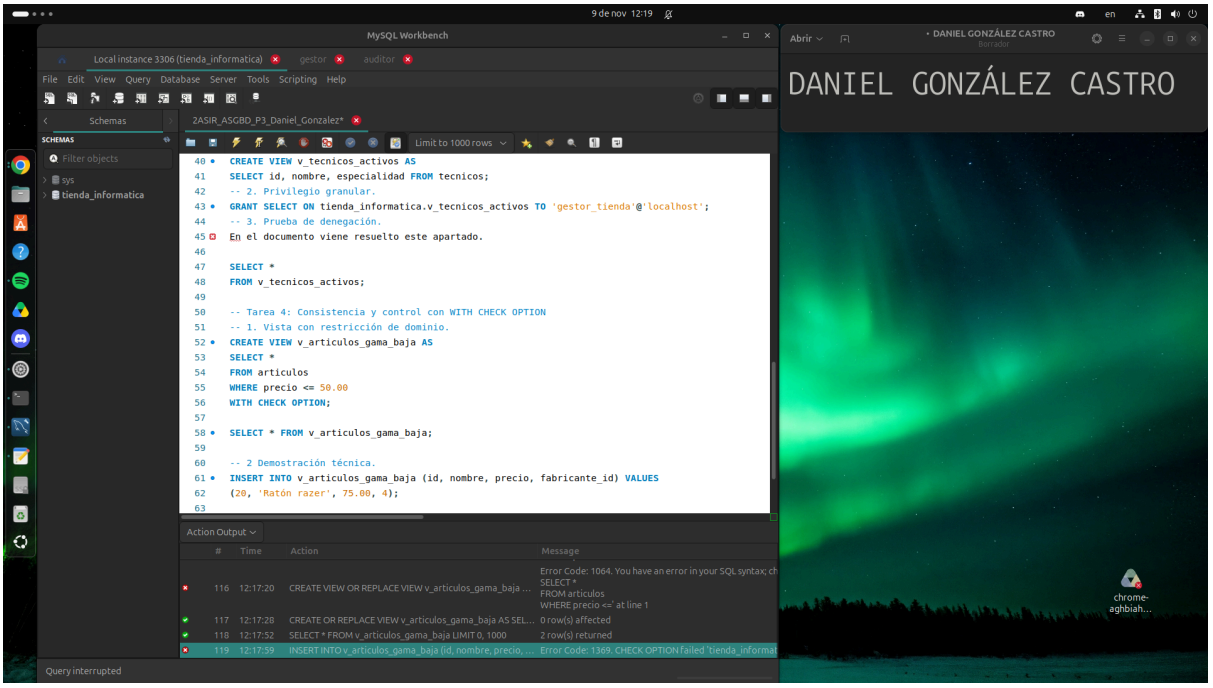
Comprueba y documenta qué ocurre si el usuario gestor_tienda intenta consultar directamente la tabla base tecnicos.

Pues en la captura de pantalla anterior podemos ver como hemos comprobado que pasaría si el usuario gestor_tienda intenta consultar alguna tabla. Y lo que pasa es que nos salta un error de permisos ya que yo mismo con permisos de root solamente le he puesto permisos de SELECT a la vista v_tecnicos_activos y no a las tablas de la propia base de datos (tienda_informatica).

Tarea 4. Consistencia y control con WITH CHECK OPTION

1. Demostración técnica

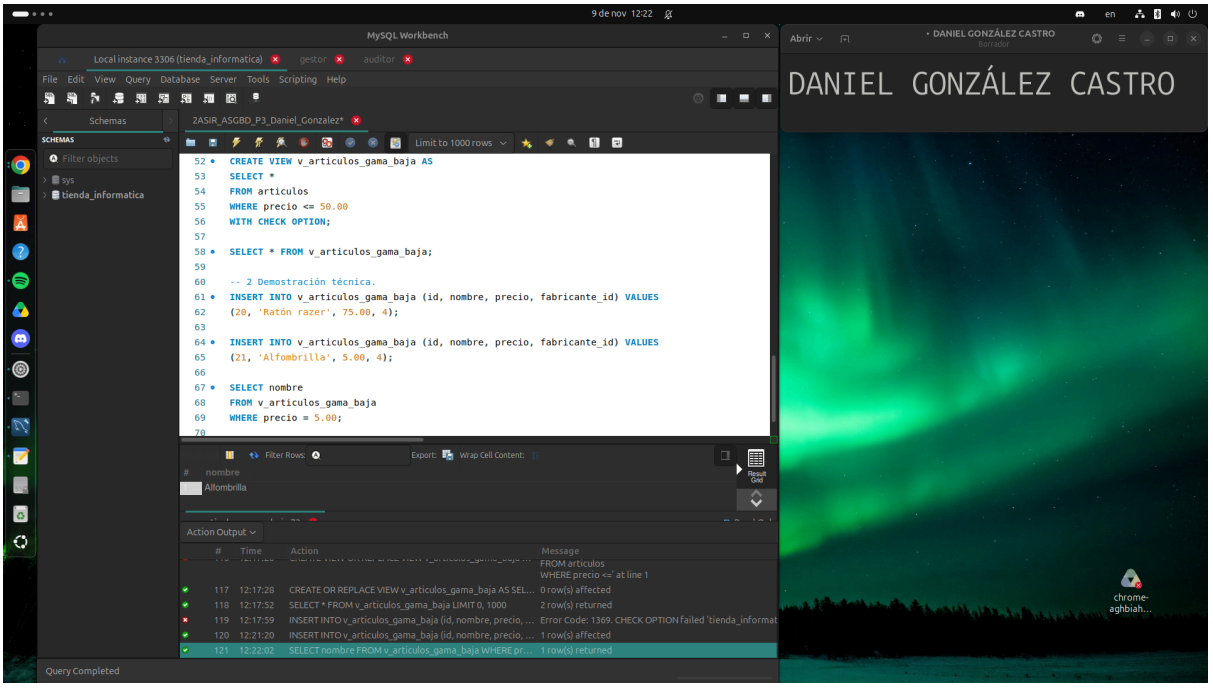
Razona y demuestra técnicamente qué sucede si el administrador o un usuario con permisos intenta realizar una inserción de un artículo con un precio de 75.00 euros a través de dicha vista.



Al intentar ejecutar la instrucción INSERT anterior, el sistema gestor de base de datos bloquea la operación y salta un error de tipo "Error Code: 1369. CHECK OPTION failed".

Esto sucede por WITH CHECK OPTION. Esta instrucción actúa como una barrera de seguridad que obliga a que cualquier inserción (INSERT) o actualización (UPDATE) realizada a través de la vista cumpla estrictamente con la condición definida en su cláusula WHERE (en este caso, que el precio sea menor o igual a 50.00). Al intentar insertar un artículo con un precio de 75.00 euros, la fila no cumple la condición de la vista, por lo que la base de datos rechaza la operación para garantizar la coherencia de los datos.

Si lo hiciéramos con un artículo que si cumpla la condición, es decir, que el precio sea menor o igual a 50.00 si nos dejaría.



Tarea 5: Auditoría, Resolución de Incidencias y Reflexión Crítica.

1. Auditoría de privilegios efectivos

Imagina que el auditor externo reporta que no puede ver los cambios recientes en la base de datos. Escribe la sentencia SQL que utilizarías para comprobar los privilegios exactos y los roles activos que tiene asignados en este momento el usuario auditor_externo desde el servidor.

SHOW GRANTS FOR 'auditor_externo'@'%';

- Esta sentencia SQL serviría para ver los roles activos que tiene asignados en ese momento el usuario auditor_externo y los permisos que tiene.

Salida:
'GRANT USAGE ON *.* TO `auditor_externo`@`%`'
'GRANT `rol_consultor`@`%` TO `auditor_externo`@`%`'

Vemos que auditor_externo no tiene ningún permiso en la base de datos tienda_informatica pero si que tiene un rol activo.

2. Reflexión sobre el Principio de Mínimo Privilegio:

Explica razonadamente por qué en un entorno de producción nunca se debe otorgar el permiso ALL PRIVILEGES a los usuarios finales de una aplicación web o de gestión, y qué relación directa guarda esta mala práctica con las inyecciones SQL o brechas de seguridad.

Si ese usuario tiene ALL PRIVILEGES, un atacante no solo podrá leer datos (hacer un SELECT de las contraseñas), sino que podrá ejecutar un DROP TABLE, borrar la base de datos entera, o incluso crear nuevos usuarios administradores con GRANT.

3. Análisis de comportamiento del CHECK OPTION:

Si un analista junior elimina la cláusula WITH CHECK OPTION en la v_articulos_gama_baja pensando que "mejora el rendimiento de las consultas", ¿qué brecha lógica o inconsistencia de datos podría introducir en la tabla base articulos al insertar registros mediante la vista? Justifica tu respuesta.

WITH CHECK OPTION obliga a que cualquier INSERT o UPDATE realizado a través de la vista cumpla obligatoriamente la condición del WHERE de dicha vista (por ejemplo, que el precio < 50 para ser gama baja).

Si el analista la quita, el gestor de la base de datos permitirá que el usuario inserte un artículo de "gama alta" (ej. precio = 500) utilizando la vista v_articulos_gama_baja.